

1. Identificação da equipe

- Carlos Gabriel
- Aliny Ramos
- Renato Souza
- Adailson ramos

2. Trilha escolhida

- VulnCase

3. Nome da ferramenta

- QAchado

4. Foco da ferramenta

Explicação objetiva: O foco da ferramenta será a gestão, priorização e documentação de achados de segurança, designado equipes de QA e Testers.

Recorte adotado: Diferente de plataformas *Enterprise* de *vulnerability management* focadas em integrações complexas e automações de varredura em larga escala, o recorte do QAchado é a gestão humana e centralizada, garantindo a documentação clara (com evidências) e rastreabilidade entre o QA e a equipe de desenvolvimento e entrega de documentação formal.

Escopo mínimo viável (MVP): A primeira versão terá o cadastro de projetos, registro manual de vulnerabilidades, atribuição de severidade e status, controle de acesso restrito entre QA e Desenvolvedor, acompanhamento do ciclo de correção e geração de um relatório consolidado da situação do projeto.

5. Funcionalidades planejadas

Funcionalidades obrigatórias (Core):

- Cadastro de projetos ou ativos.
- Controle de acessos baseado em perfis (QA com acesso total; Dev com acesso restrito a projetos atribuídos).
- Cadastro de vulnerabilidades (Título, descrição, severidade, recomendação de correção).
- Fluxo de status da vulnerabilidade (Aberto, Em Correção, Pronto para Reteste, Corrigido, Risco Aceito).
- Upload e armazenamento de evidências (imagens e logs).
- Visualização consolidada dos registros (Dashboard simples).
- Geração básica de relatório para exportação (PDF ou Markdown).

Funcionalidades desejáveis/opcionais (Diferenciais):

- Deduplicação inteligente de achados (aviso de similaridade ao cadastrar).
- Integração com motor de IA Local (SLM) para sumarização automática de descrições longas.

- Geração de relatórios avançados baseados em leitura de *templates* (ex: upload de arquivo .docx com tags dinâmicas).
- Associação rápida a catálogos do mercado (OWASP, CWE, CVE).

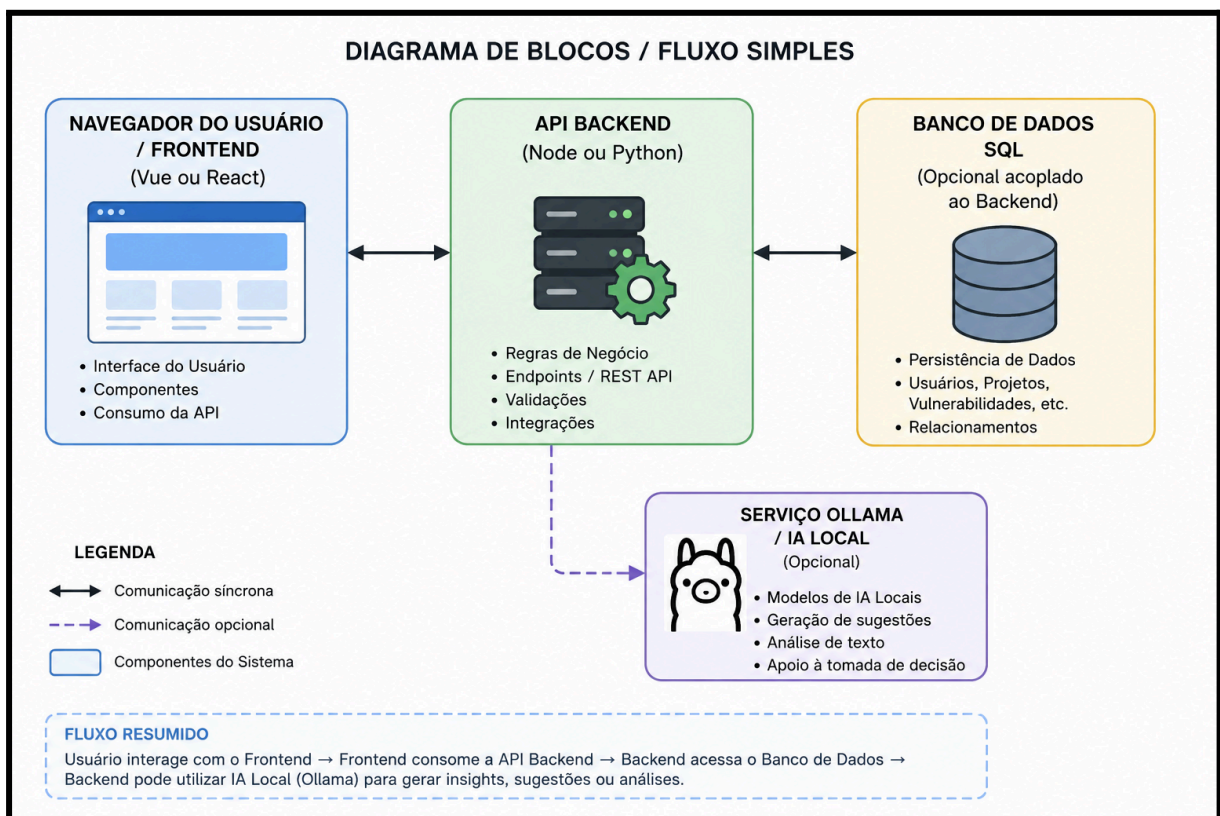
6. Arquitetura inicial

Descrição resumida: A aplicação utilizará uma arquitetura Cliente-Servidor (Frontend desacoplado do Backend). A comunicação será feita via API RESTful. O armazenamento de dados relacionais será mantido em um banco SQL, e as evidências serão salvas no disco local do servidor ou máquina local. Opcionalmente, um serviço local de IA responderá a requisições HTTP do backend para geração de resumos.

Lista de módulos:

1. Autenticação e Controle de Acesso
2. Projetos e Ativos
3. Registro e Ciclo de Vida de Vulnerabilidades
4. Inteligência Local e Deduplicação
5. Evidências e Armazenamento
6. Business Intelligence (BI) e Geração de Relatórios

Diagrama de Blocos / Fluxo Simples:



7. Módulos principais

1. **Módulo de Autenticação e Perfis:** Gerencia o login e valida se o usuário é QA (Admin) ou Desenvolvedor.

2. **Módulo de Projetos/Ativos:** Onde os ambientes ou softwares testados são cadastrados.
3. **Módulo de Vulnerabilidades:** O formulário de achados, histórico de alterações, comentários e anexos.
4. **Módulo de Relatórios e BI:** Responsável por compilar os achados de um projeto em gráficos visuais e exportar os arquivos formatados.

8. Fluxo principal de uso

1. O **QA** acessa o sistema, cria um *Projeto* (ex: "App de Vendas v2.0") e inicia os testes.
2. Ao encontrar uma falha, o QA registra a vulnerabilidade informando os detalhes, severidade, faz upload de um print (evidência) e atribui a um **Desenvolvedor** responsável.
3. O Desenvolvedor acessa a ferramenta, visualiza apenas os achados atribuídos a ele.
4. Após corrigir o código, o Desenvolvedor muda o status do achado para "*Pronto para Reteste*" e adiciona um comentário técnico.
5. O QA visualiza a mudança, valida a correção no ambiente e altera o status final para "*Corrigido / Fechado*".
6. Ao fim do ciclo, o QA clica em "Gerar Relatório" para entregar a documentação consolidada ao cliente/gestor.

9. Tecnologias previstas

Frontend: React (com Vite) ou Vue.js, utilizando TailwindCSS para a interface.

Backend: Python (FastAPI) ou Node.js (Express), focados em construção rápida de APIs REST.

Banco de Dados: PostgreSQL ou SQLite (para facilidade de setup local).

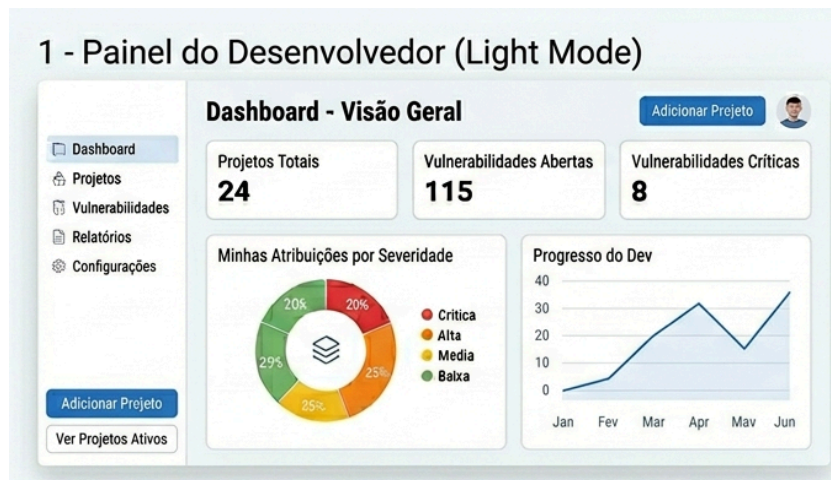
IA Local (Desejável): Ollama rodando modelos leves (ex: Llama 3 8B ou Phi-3).

10. Organização inicial da equipe

- **Aliny:** Frontend e UX/UI.
- **Renato:** Backend (modelagem do Banco de Dados e criação das APIs).
- **Carlos:** Backend (Documentação, gestão do repositório/entregas e motor de exportação de relatórios)
- **Adailson:** Integração da IA / Deduplicação e com DBs e drivers/ armazenamentos em nuvem.

11. Protótipo de telas

Tela 1 - Dashboard Inicial: Uma visão geral contendo cards com o total de projetos, um gráfico de pizza mostrando vulnerabilidades por severidade e atalhos rápidos.



Tela 2 - Lista de Achados (Kanban ou Tabela): Uma tela dentro de um projeto mostrando todas as falhas, permitindo filtrar por "Status" e "Responsável".



Tela 3 - Cadastro/Edição de Vulnerabilidade: Um formulário limpo para inserir Título, Descrição, Severidade, botão de upload de Evidências (drag-and-drop) e o botão "Gerar Resumo com IA" ao lado do campo de descrição.

3. Cadastro/Edição de Vulnerabilidade (Light Mode)

CADASTRO DE VULNERABILIDADE
Título
Reflected XSS on Login
Descrição
Stato JWTs can be reused by an attacker to impersonate a user...
Severidade
Critical
Responsável
Ahmad J.
EVIDENCE
image_screenshot_0.png
server_logs.txt

Tela 4 - Visão do Desenvolvedor: Uma tela simplificada e restrita mostrando apenas os detalhes da falha que ele precisa corrigir e um seletor para mudar o status para "Pronto para Reteste".

4. Visão do Desenvolvedor (Restricted, Light Mode)

Minhas Atribuições / Reflected XSS
MY ASSIGNMENTS
Título
Cross-site Scripting (XSS) on User Profile Page
Descrição (Summarized)
A stored XSS vulnerability was found on the user profile edit page, od tempor incididunt ut labore et dolore magna aliquis. (A wim nininn veniam, auis noxtrud exeisitation.
Atualizar Status
Pronto para Reteste
Em Correção
Risco Aceito
Submit Action

12. Link do repositório

<https://github.com/alisouzr/QAchado>